

Welcome to

Introduction to Offensive Security

Saint Cyber – Cyber Akademiet, 2026

Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

Slides are available as PDF, https://codeberg.org/kramse
academy-2026-day0-intro.tex in the repo security-courses

© license CC BY 3.0. 2026 Henrik Kramselund

Goals for today



- Explain offensive security as an authorised simulation of adversary tools, tactics and techniques
- Distinguish vulnerability scanning, vulnerability management, penetration testing and simulated attack exercises
- Apply the core penetration-testing lifecycle
- Define scope, objectives, testing conditions and rules of engagement before testing
- Assess vulnerability severity using CVSS and prioritise remediation
- Perform structured reconnaissance with authorised active and passive methods

Plan for today



- What offensive security is – and authorised vs unauthorised
- The three types + CVSS and prioritisation
- Planning, scope, rules of engagement and reporting
- The toolbox and the lab
- Reconnaissance: whois, ping, traceroute, Nmap
- Passwords and cracking

Time schedule



- 08:30–10:00 What is offensive security; types; CVSS
- 10:00–10:15 Break
- 10:15–11:45 Methodology, scope, rules of engagement, reporting
- 11:45–12:30 Recon + Nmap – **exercise** (booklet)
- 12:30–13:15 Lunch

Hacker – cracker



Short answer – dont discuss this

Yes, originally there was another meaning to hacker, but the media has perverted it and today, and since early 1990s it has meant breaking into stuff for the public

Today a hacker breaks into systems!

Reference. Spafford, Cheswick, Garfinkel, Stoll, . . . - wrote about this and it was lost

Story is interesting and the old meaning is ALSO used in smaller communities, like hacker spaces full of hackers - doing fun and interesting stuff

- *Cuckoo's Egg: Tracking a Spy Through the Maze of Computer Espionage*, Clifford Stoll
- *Hackers: Heroes of the Computer Revolution*, Steven Levy
- *Practical Unix and Internet Security*, Simson Garfinkel, Gene Spafford, Alan Schwartz

Hackers don’t give a shit

Your system is only for testing, development, ...

Your network is a research network, under construction, being phased out, ...

Try something new, go to your management

Bring all the exceptions, all of them, update the risk analysis figures - if this happens it is about 1mill DKK

Ask for permission to go full monty on your security

Think like attackers - don’t hold back



Technically what is hacking



Hacking is magic



Hacking looks like magic

Hacking is not magic



Hacking only demands ninja training and knowledge others don't have

Why even do security testing?



Lots of security problems

Pentesting may be a requirement from external partners – example VISA PCI standard

- Boss asking: should we do a security test?
- CIO: hmm, okay
- IT Admins: *sigh* – I know the security sucks in places!
- Its not your systems – dont take the criticism personal, but as an opportunity to get things improved

- Pentest tools are great resources for doing discovery of assets, evaluating the security of large installations quickly – in short using pentest tools makes you more efficient!

Many see the benefits after doing a pentest, so try it!

Benefits of having a planned security test done



Goal of testing is to reduce risk for the systems and secure the organisation from unexpected loss of data, image and increased costs.

Intended audience:

- IT-department and technical personnel
- Management and board
- External auditors, government, financial control VISA/PCI, the public

Output from testing:

- Reports with technical content and recommendations
- Executive summary

Goal is not to find a scape goat to blame – management allocates resources

If security is below in places more resources may be needed.

The three types of offensive security



- **FIXME:** vulnerability management & scanning / penetration testing / simulated attack exercises
- **FIXME:** one line each on objective + limitation (subject plan obj 2)

CVSS – severity scoring



- **FIXME:** not in pentest-l-introduction: add base/temporal/environmental
- **FIXME:** worked exercise on a current CVE; likelihood x impact (subject plan obj 6)

Agreements for testing networks



> Danish Criminal Code
> Straffelovens paragraf 263 Stk. 2. Med bøde eller fængsel indtil 1 år og 6 måneder straffes den, der uberettiget skaffer sig adgang til en andens oplysninger eller programmer, der er bestemt til at bruges i et informationssystem.

Hacking can result in:

- Getting your devices confiscated by the police
- Paying damages to persons or businesses
- If older getting a fine and a record – even jail perhaps
- Getting a criminal record, making it hard to travel to some countries and working in security
- Fear of terror has increased the focus – so dont step over bounds!

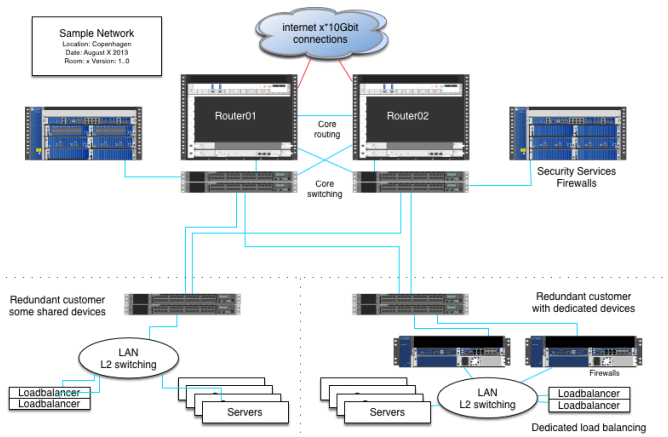
Asking for permission and getting an OK before doing invasive tests, always!

Planning a pentest



- Scope – what is being tested
- When is the testing done – time frame, wall clock time
- Where are the attacks coming from – log files will contain the attacks
  but other attacks from other sources are likely during the attacks, which must be blocked
- We sometimes go broader than the scope – perhaps checking the router in front with SNMP or doing a small port 80/tcp scan
- Agree if Denial of Service is to be tested
- TL;DR Rules of engagement for the project

Selecting systems for testing



- Routers on the way to critical systems and networks – especially availability
- Firewall – is the environment protected sufficiently, discarding probes
- Mail servers – relay testing and also critical data
- Web servers – holds data, typically has a lot of functionality
- Cloud systems, storage systems, anywhere data is saved

Testing Agreement and Scope Example



Usually the scope could include targets like these:

- 192.168.1.1 – firewall/router
- 192.168.1.2 – mail server
- 192.168.1.3 – web server
- Test to be done from monday 1st until friday 5th
- Testing done from 192.0.2.0/28

When testing web servers and sites, especially API – please include hostname, URLs, documentation. If not included some sites and functionality will NOT be tested!

Rules of engagement – rules and ethics for security testing



- NB: big difference between Denmark and other places!
- Security consultant must not be the cause of new vulnerabilities due to the testing
- Security consultant must not install new software on systems without previous agreement
- Security consultant is not to leave insecure system administrator accounts or settings after testing
- Security consultant always contact the customer in case of high-risk vulnerabilities
- It is allowed to peek around in the network – checking if there might be an insecure development or testing server near by
- If you meet other security problems outside of the scope we still report them, but perhaps in an appendix

In general be careful of other people networks and systems

Reporting – results



What is in a pentest report:

- Title, Table of contents, formal report thanks
- Confidentiality agreement – Write "Confidential" on each page
- Executive summary – big companies always want this
- Information about the scan done, what was it
- Scope and targets
- Review of all targets – detailed information and recommendations
- Conclusion – may be more technical
- Appendices – various information, Whois info about subnets and prefixes

BTW When delivering a report, it is up to the organisation to decide which recommendations to implement

Sample report available at: https://github.com/kramse/pentest-report

Materials – where to start



- This presentation – slides for today, start here
- Setup instructions for creating a Kali virtual machine:
  https://github.com/kramse/kramse-labs
- Getting started in infosec BornHack Youtube has the video

  https://github.com/kramse/security-courses/tree/master/presentations/misc/getting-started-in-infosec
- Nmap Workshop exercises

  https://github.com/kramse/security-courses/blob/master/courses/pentest/nmap-workshop/nmap-workshop-exercises.pdf
- Older Pentest course exercises

  https://github.com/kramse/security-courses/blob/master/courses/pentest/kea-pentest/kea-pentest-exercises.pdf
- Also the Simulated DDoS Workshop on BornHack 17-24 2024 – among others:

  https://github.com/kramse/security-courses/tree/master/presentations/pentest/simulated-ddos-workshop

Start a download of Kali today, if you want to play with the tools tomorrow
Recommend virtual machine download 64-bit https://www.kali.org/get-kali/#kali-virtual-machines

Books and Educational Materials



- *The Linux Command Line: A Complete Introduction*, 2nd Edition
  by William Shotts, internet edition https://sourceforge.net/projects/linuxcommand
- *Linux Basics for Hackers Getting Started with Networking, Scripting, and Security in Kali*. OccupyTheWeb, December 2018, 248 pp. ISBN-13: 978-1-59327-855-7
- *Gray Hat Hacking: The Ethical Hacker's Handbook*, 6. ed. Allen Harper and others ISBN: 9781264268948
- *Web Application Security*, Andrew Hoffman, 2020, ISBN: 9781492053118
- *Practical Packet Analysis, Using Wireshark to Solve Real-World Network Problems* by Chris Sanders, 3rd ed, ISBN: 978-1-59327-802-1
- *Hacking, 2nd Edition: The Art of Exploitation*, Jon Erickson, February 2008, ISBN-13: 9781593271442
- *Kali Linux Revealed Mastering the Penetration Testing Distribution*
  https://www.kali.org/

We teach using these books at Copenhagen School of Design and Technology (KEA)

Hacker tools



> We realize that SATAN is a two-edged sword – like many tools, it can be used for good and for evil purposes. We also realize that intruders (including wannabees) have much more capable (read intrusive) tools than offered with SATAN.

Source: http://www.fish2.com/security/admin-guide-to-cracking.html

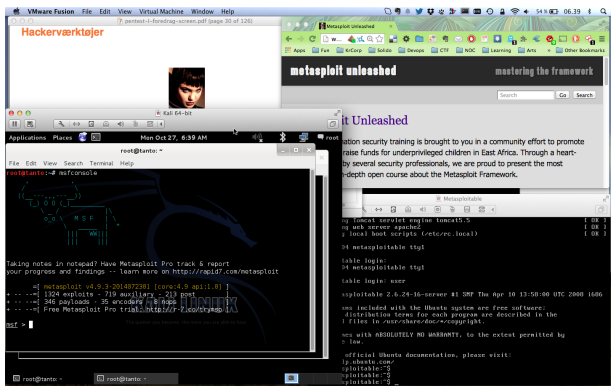
- I got into hacking due to the security papers from Spaff and others, like this: *Improving the Security of Your Site by Breaking Into it*, Dan Farmer and Wietse Venema, 1993
- Later in 1995 released the software SATAN
  Security Administrator Tool for Analyzing Networks
- Caused some commotion, panic and discussions, every script kiddie can hack, the Internet will melt down!

Use hacker tools!



- Port scan can reveal holes in your defense
- Web testing tools can crawl through your site and find problems
- Pentesting is a verification and proactively finding problems
- Its not a silverbullet and mostly find known problems in existing systems
- Combined with honeypots they may allow better security

Hacker lab setup



- Hardware: any modern laptop with CPU and virtualisation
  Don't forget to enable it in the BIOS
- Software: your favourite operating system Windows, Mac, Linux, ...
- Virtualisation software: VMware, Virtual box, pick your poison
- Hacker software: Kali as a Virtual Machine https://www.kali.org/
- Soft targets: Metasploitable, Linux, Microsoft Windows, Microsoft Exchange, Windows server, ...

Kali Linux the pentest toolbox

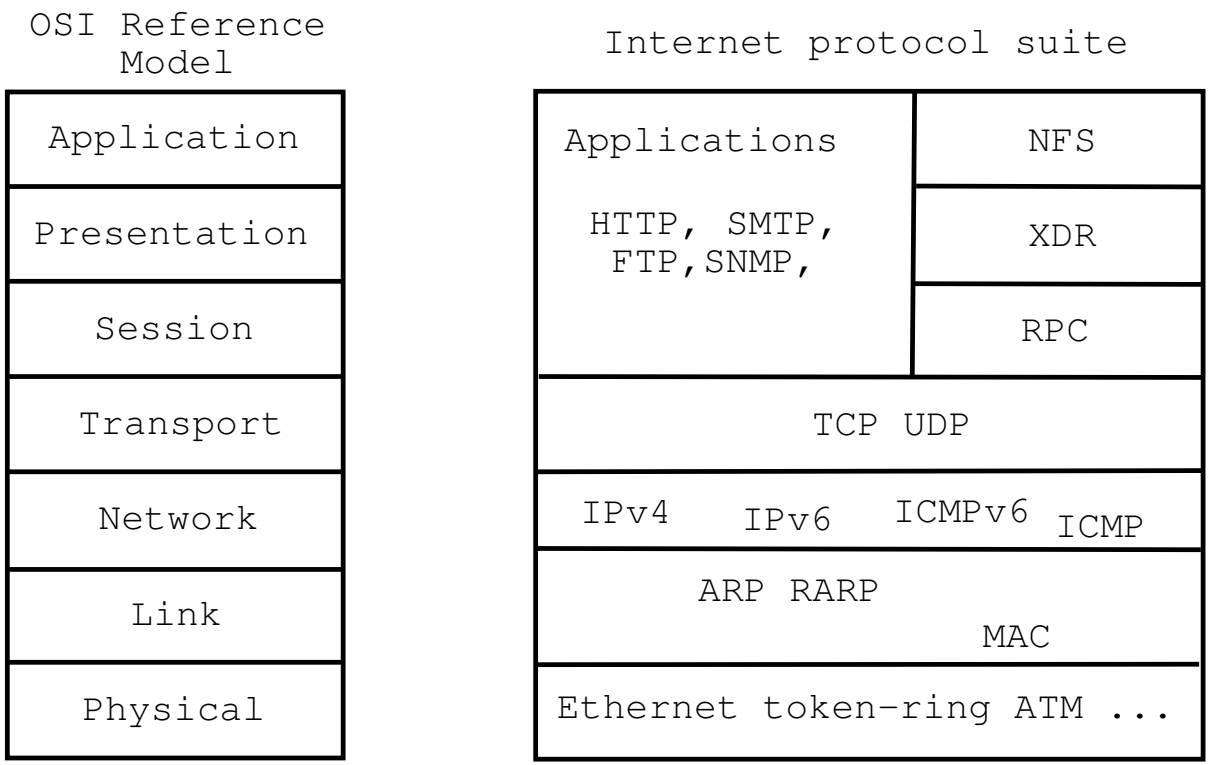


Kali http://www.kali.org/

100.000s of videos on youtube alone, searching for kali and $TOOL

Also versions for Raspberry Pi, mobile and other small computers

OSI Model and Internet Protocols



Recommended technologies to learn



So to accomplish the goal of using Nmap efficiently you need some basics

Networking: Basic Protocols from the Internet Protocols suite IP/TCP, or TCP/IP

- Network Layer: Ethernet, Address Resolution Protocol (ARP), IPv4 and ICMP
  Later add Wi-Fi and IPv6
- Transport Layer: Transmission Control Protocol (TCP) and User Datagram Protocol (UDP)
- Common upper layer: Dynamic Host Configuration Protocol (DHCP), Domain Name System (DNS), Hypertext Transfer Protocol (HTTP)
  Later add the encrypted/secure versions like Hypertext Transfer Protocol Secure (HTTPS) which uses Transport Layer Security (TLS)

Pro tip: always say Ethernet frames and IP packets. No one uses datagram anymore.

Pro tip: If you *really know DNS* you can make a huge impact in the malware area!

Whois – Where do IP addresses come from



Magical numbers on the internet are administered by IANA https://www.iana.org/

They have handed out portions to the Region Internet Registries (RIR)

- RIPE (Réseaux IP Européens) http://ripe.net
- ARIN American Registry for Internet Numbers http://www.arin.net
- Asia Pacific Network Information Center http://www.apnic.net
- LACNIC (Regional Latin-American and Caribbean IP Address Registry) - Latin America and some Caribbean Islands
- AFRINIC https://afrinic.net/

They are member based, and members are called Local Internet Registries (LIRs) og National Internet Registry (NIR)

We use the whois program to look up addresses, can be found as web pages too

Ping



Internet Control Message Protocol (ICMP)

The ping program works by sending `ICMP ECHO request` and we expect an `ICMP ECHO reply`

```
$ ping 185.129.63.1
PING 185.129.63.1 (185.129.63.1) 56(84) bytes of data.
64 bytes from 185.129.63.1: icmp_seq=1 ttl=54 time=8.14 ms
64 bytes from 185.129.63.1: icmp_seq=2 ttl=54 time=31.5 ms
64 bytes from 185.129.63.1: icmp_seq=3 ttl=54 time=22.4 ms
64 bytes from 185.129.63.1: icmp_seq=4 ttl=54 time=12.2 ms
^C
--- 185.129.63.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 8.144/18.544/31.463/9.095 ms
```

Try it yourself, this should work on most operating systems `ping 185.129.63.1`

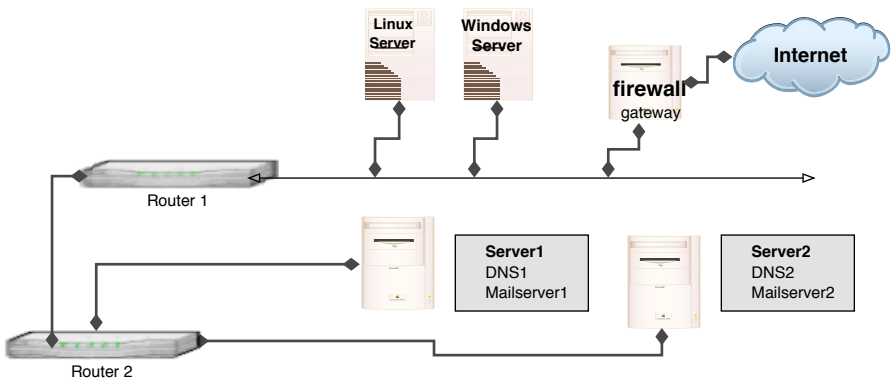
traceroute



- Another *hacker program* is traceroute – and I call it that since it uses the Time To Live (TTL) on IPv4 or Hop limit (IPv6) field in packets, not something that was designed as a feature
- Researcher found that if they sent packets with low TTL and sent it to high numbered UDP ports, they would usually get an answer
- Routers decrease the TTL counter, and send back ICMP messages, end hosts not listening on a port do the same
- Traceroute can be done with various protocols, but usually Unix uses UDP and Windows uses ICMP (tracert)

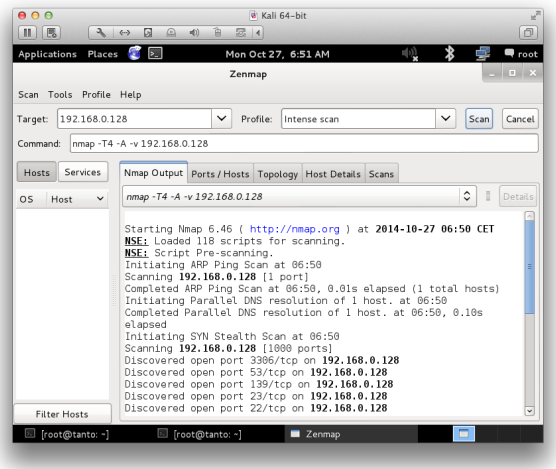
```
$ traceroute 185.129.63.1
traceroute to 185.129.63.1 (185.129.63.1),
30 hops max, 40 byte packets
 1  host11 (10.0.0.11)  3.577 ms  0.565 ms  0.323 ms
 2  router (185.129.63.1)  1.481 ms  1.374 ms  1.261 ms
```

Network mapping



- Using traceroute, Nping and similar programs you can often discover topoly information about a network
- Time to Live (TTL) for a packet is decremented for each router it crosses, if set low enough it will time out – and return ICMP message sent
- BTW Default Unix traceroute sends UDP packets, Windows tracert send ICMP packets
  Use tools on Kali to try both protocols, or even others

Really do Nmap your world



- Nmap is a port scanner, but does more
- Finding your own infrastructure available from the guest network?
- See your printers having all the protocols enabled AND a wireless?

Basic Portscan



What is port scanning

Testing all ports from 0/1 up to 65535

Goal is to identify open ports – vulnerable services

Typically TCP and UDP scans

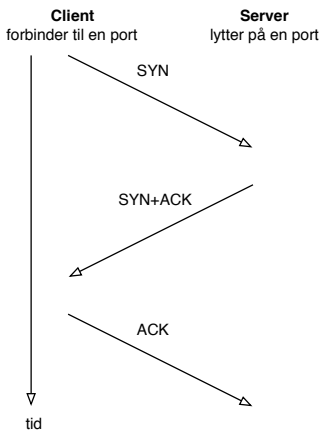
TCP scanning is more reliable than UDP scanning

TCP handshake is easy to see, due to session setup – services must respond to SYN with SYN-ACK. Otherwise client programs like browsers will not work

UDP applications respond differently – if at all
They might respond to queries and probes in the correct format,
If no firewall the operating systems will respond with ICMP on closed ports

Use Zenmap while learning Nmap

TCP three-way handshake



- **TCP SYN half-open** scans
- In the old days systems would only log a full TCP connection – so a port scanner sending only SYN would be doing a *stealth*-scans. Today we have Intrusion Detection Systems, so a lot of SYN without ever completing the connection is MORE suspicious
- Note: sending many SYN packets can fill the session table on firewalls, and on servers – preventing new connections – also called **SYN-flooding**

Ping and port sweep



Scanning across a network is called sweeping

Scans using ICMP ping will be a ping-sweep – active IPs

Scans using specific ports are port-sweeps

Easy to detect using modern intrusion detection systems (IDS)

Pro tip: If you are looking for an IDS, look at Suricata https://suricata.io and Zeek https://zeek.org/ – together

Nmap port sweep for web services



```
root@cornerstone:~#  nmap -p80,443 172.29.0.0/24

Starting Nmap 6.47 ( http://nmap.org ) at 2015-02-05 07:31 CET
Nmap scan report for 172.29.0.1
Host is up (0.00016s latency).
PORT    STATE    SERVICE
80/tcp  open     http
443/tcp filtered https
MAC Address: 00:50:56:C0:00:08 (VMware)

Nmap scan report for 172.29.0.138
Host is up (0.00012s latency).
PORT    STATE  SERVICE
80/tcp  open   http
443/tcp closed https
MAC Address: 00:0C:29:46:22:FB (VMware)
```

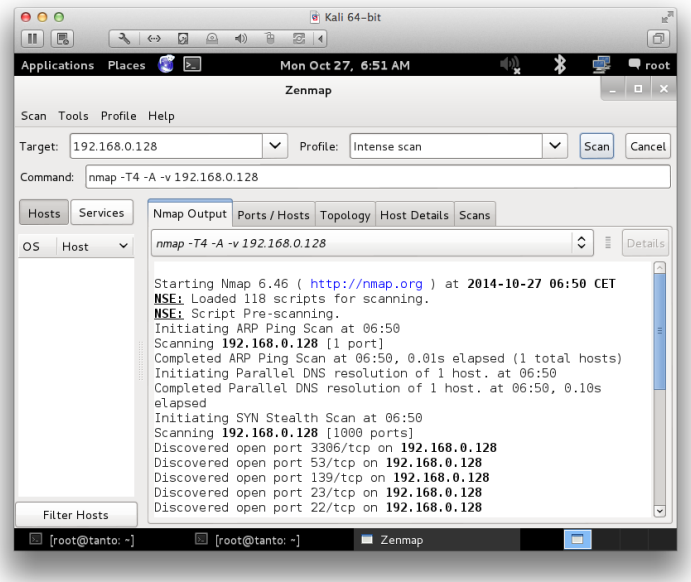
Nmap Advanced OS detection



```
root@cornerstone:~# nmap -A -p80,443 172.29.0.0/24
Starting Nmap 6.47 ( http://nmap.org ) at 2015-02-05 07:37 CET
Nmap scan report for 172.29.0.1
Host is up (0.00027s latency).
PORT    STATE    SERVICE VERSION
80/tcp  open     http    Apache httpd 2.2.26 ((Unix) DAV/2 mod_ssl/2.2.26 OpenSSL/0.9.8zc)
|_http-title: Site doesn't have a title (text/html).
443/tcp filtered https
MAC Address: 00:50:56:C0:00:08 (VMware)
Device type: media device|general purpose|phone
Running: Apple iOS 6.X|4.X|5.X, Apple Mac OS X 10.7.X|10.9.X|10.8.X
OS details: Apple iOS 6.1.3, Apple Mac OS X 10.7.0 (Lion) - 10.9.2 (Mavericks)
or iOS 4.1 - 7.1 (Darwin 10.0.0 - 14.0.0), Apple Mac OS X 10.8 - 10.8.3 (Mountain Lion)
or iOS 5.1.1 - 6.1.5 (Darwin 12.0.0 - 13.0.0)
OS and Service detection performed.
Please report any incorrect results at http://nmap.org/submit/
```

- Low level operating system identification, often I use `nmap -A`
- Send packets, observe responses, match with tables of known operating system fingerprints
- An early reference for this was: *ICMP Usage In Scanning* Version 3.0, Ofir Arkin, 2001

Demo: Nmap and Zenmap



- Short demo, Nmap, Zenmap – and don't forget Nping
- Later try yourself, find exercises in nmap-workshop-exercises.pdf

Nping from the Nmap package



```
root@KaliVM:~# nping --tcp -p 80 www.zencurity.com

Starting Nping 0.7.70 ( https://nmap.org/nping ) at 2018-09-07 19:06 CEST
SENT (0.0300s) TCP 10.137.0.24:3805 > 185.129.63.130:80 S ttl=64 id=18933 iplen=40  seq=2984847972 win=1480
RCVD (0.0353s) TCP 185.129.63.130:80 > 10.137.0.24:3805 SA ttl=56 id=49674 iplen=44  seq=3654597698 win=16384 <mss 1460>
SENT (1.0305s) TCP 10.137.0.24:3805 > 185.129.63.130:80 S ttl=64 id=18933 iplen=40  seq=2984847972 win=1480
RCVD (1.0391s) TCP 185.129.63.130:80 > 10.137.0.24:3805 SA ttl=56 id=50237 iplen=44  seq=2347926491 win=16384 <mss 1460>
SENT (2.0325s) TCP 10.137.0.24:3805 > 185.129.63.130:80 S ttl=64 id=18933 iplen=40  seq=2984847972 win=1480
RCVD (2.0724s) TCP 185.129.63.130:80 > 10.137.0.24:3805 SA ttl=56 id=9842 iplen=44  seq=2355974413 win=16384 <mss 1460>
SENT (3.0340s) TCP 10.137.0.24:3805 > 185.129.63.130:80 S ttl=64 id=18933 iplen=40  seq=2984847972 win=1480
RCVD (3.0387s) TCP 185.129.63.130:80 > 10.137.0.24:3805 SA ttl=56 id=1836 iplen=44  seq=3230085295 win=16384 <mss 1460>
SENT (4.0362s) TCP 10.137.0.24:3805 > 185.129.63.130:80 S ttl=64 id=18933 iplen=40  seq=2984847972 win=1480
RCVD (4.0549s) TCP 185.129.63.130:80 > 10.137.0.24:3805 SA ttl=56 id=62226 iplen=44  seq=3033492220 win=16384 <mss 1460>

Max rtt: 40.044ms | Min rtt: 4.677ms | Avg rtt: 15.398ms
Raw packets sent: 5 (200B) | Rcvd: 5 (220B) | Lost: 0 (0.00%)
Nping done: 1 IP address pinged in 4.07 seconds
```

Awesome tool for testing firewall rules, sending probes with specific source port etc.

Passwords are not chosen completely random





Source: https://wpengine.com/unmasked/

Brute force



We call it brute force – when testing all possibilities

```
Hydra (c) by van Hauser / THC <vh@thc.org>
Syntax: hydra [[[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]]
[-o FILE] [-t TASKS] [-g TASKS] [-T SERVERS] [-M FILE] [-w TIME]
[-f] [-e ns] [-s PORT] [-S] [-vV] server service [OPT]

Options:
  -S         connect via SSL
  -s PORT    if the service is on a different default port, define it here
  -l LOGIN   or -L FILE login with LOGIN name, or load several logins from FILE
  -p PASS    or -P FILE try password PASS, or load several passwords from FILE
  -e ns      additional checks, "n" for null password, "s" try login as pass
  -C FILE    colon seperated "login:pass" format, instead of -L/-P option
  -M FILE    file containing server list (parallizes attacks, see -T)
  -o FILE    write found login/password pairs to FILE instead of stdout
...
```

Cracking passwords – JtR and Hashcat



John the Ripper is a fast password cracker, currently available for many flavors of Unix (11 are officially supported, not counting different architectures), Windows, DOS, BeOS, and OpenVMS. Its primary purpose is to detect weak Unix passwords.

- Hashcat is the world's fastest CPU-based password recovery tool.
- oclHashcat-plus is a GPGPU-based multi-hash cracker using a brute-force attack (implemented as mask attack), combinator attack, dictionary attack, hybrid attack, mask attack, and rule-based attack.
- oclHashcat-lite is a GPGPU cracker that is optimized for cracking performance. Therefore, it is limited to only doing single-hash cracking using Markov attack, Brute-Force attack and Mask attack.
- John the Ripper password cracker old skool men stadig nyttig

Source:
https://hashcat.net/wiki/
http://www.openwall.com/john/

Principle of Least Privilege



Many programs need privileges to perform some function, but sometimes they don't really need it

Definition 14-1 The *principle of least privilege* states that a subject should be given only those privileges that it needs in order to complete the task.
Source: *Computer Security: Art and Science*, 2nd edition, Matt Bishop

Also drop privileges when not needed anymore, relinquish rights immediately

Example, need to read a document - but not write.

Database systems can often provide very fine grained access to data

Recommendations During Test



- Run each test for at least 5 minutes, or even 15 minutes
  Some attacks require some build-up before resource run out
- Take note of any change in response, higher latency, lost probes
- If you see a change, then re-test using the same parameters, or a little less first
- We want to know the approximate level where it breaks
- If you want to change environment, then wait until all scenarios are tested
- Keep a log handy, write notes and start the session with `script ddos-date-customer.log`
- Check once in a while if you have some process running, using `ps auxw | grep hping3`
- Run multiple instances of the tools. One process might generate 800.000 pps, while two may double it. Though 10 processes might not be 10 times exactly

Summary & references



- Offensive security is authorised, scoped testing that improves the security posture
- Agree scope and rules of engagement first; report for technical and management audiences
- *Web Application Security*, Andrew Hoffman, 2020, ISBN: 9781492053118 (WAS)
- Sample pentest report: https://github.com/kramse/pentest-report